

# DATATRUST SOLUTIONS GRC AUDIT & STRATEGY REPORT

**Prepared by:** Solomon Mwaura  
**Date:** February 11, 2026  
**Subject:** Governance, Risk, and Compliance Modernization

## 1. GRC Objectives and Scope

Based on Section 1 of the audit report.

The primary goal is to modernize the framework to match rapid organizational growth. Key objectives include closing SOC 2 and GDPR gaps, transitioning from reactive to automated risk management, and unifying IT/business governance.

- **Systems in Scope:** Cloud Database (Client Data), ITSM Platform, and IDS.
- **Regulatory Focus:** SOC 2 (Security/Availability) and GDPR (Data Privacy).

## 2. Current State Assessment

Based on Sections 2, 3, and 4 of the audit report.

| Area            | Strengths                                                         | Critical Gaps                                                                              |
|-----------------|-------------------------------------------------------------------|--------------------------------------------------------------------------------------------|
| Governance      | Established IT operations and regular incident response meetings. | Siloed departments and a lack of a unified "GRC Committee."                                |
| Risk Management | Core cybersecurity risks are identified.                          | Manual tracking in spreadsheets; no automated risk scoring or remediation tracking.        |
| Compliance      | Existing IDS and baseline security controls.                      | Missing GDPR data transfer policies; Cloud Database lacks MFA and full encryption at rest. |

## 3. Proposed GRC Framework Improvements

Based on Section 5 and 6 of the audit report.

- **Automation:** Replace manual spreadsheets with a dedicated GRC platform to provide real-time visibility and automated control testing.
- **Policy Development:** Draft comprehensive Data Privacy Impact Assessments (DPIAs) and international data transfer agreements to meet GDPR requirements.

- **Technical Controls:** Immediate enforcement of Multi-Factor Authentication (MFA) and AES-256 encryption for the Cloud Database.

## 4. Strategic Roadmap

*Based on Section 7: Action Plan.*

| Timeline                | Key Actions                                                                      |
|-------------------------|----------------------------------------------------------------------------------|
| Immediate (0-30 Days)   | Conduct GDPR gap analysis; implement MFA on Cloud Database.                      |
| Short Term (30-90 Days) | Form GRC Committee; select GRC software; standardize ITSM workflows.             |
| Long Term (3-6 Months)  | Migrate data to GRC platform; conduct mock SOC 2 audit; launch training program. |